



CYBER DEFENSE (420-Do3-AB) — CLASSES 5 & 6

Securing Windows and Linux Hosts

Hardening and host firewalls — LAB_03

Saturday, September 12, 2026 · 8:30 – 10:00 · then supervised laboratory time

Cybersecurity AEC (Attestation d'études collégiales) — LEA.D8 · Competency EZO3 — To apply access control measures

Prepared by Cyber.SoHo

What we do today

Part 1 — Hardening (Class 5 topics)

1.1 What hardening means 10 min

1.2 Windows and Linux hardening measures 12 min

1.3 Monitoring and remediating vulnerabilities 10 min

1.4 Validation with free baselines (CIS) 10 min

Part 2 — Host firewalls (Class 6 topics)

2.1 Host firewalls vs network firewalls 9 min

2.2 Defender Firewall, UFW, firewalld 12 min

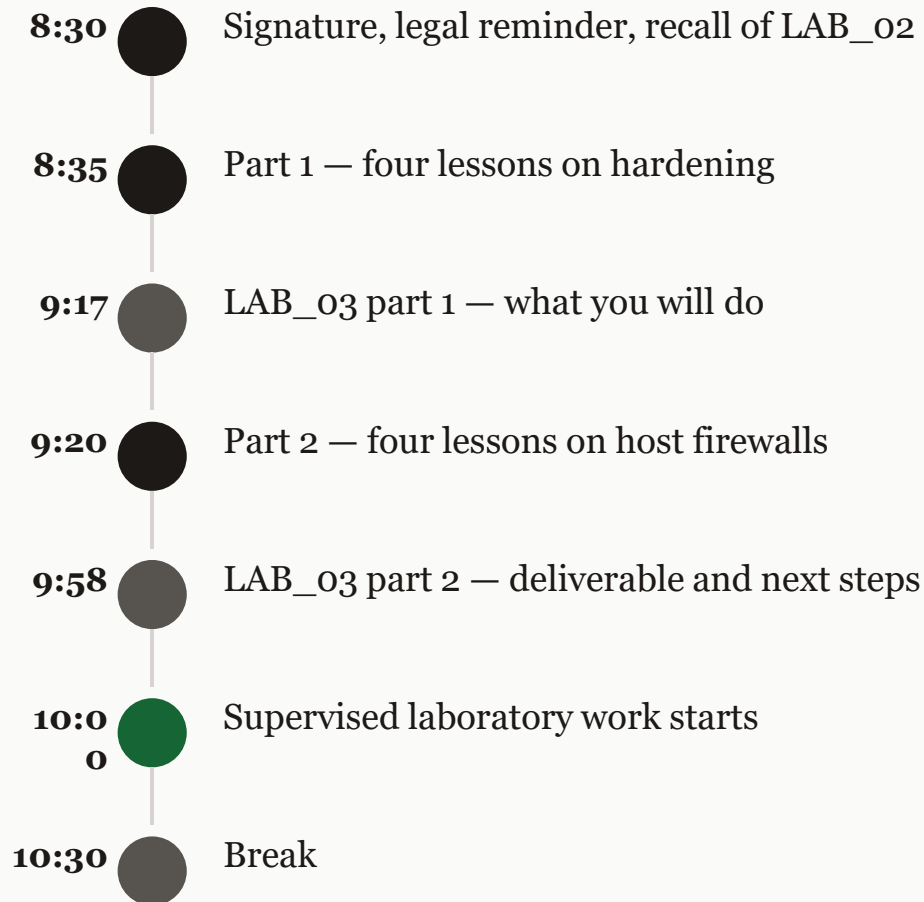
2.3 Rules chosen by the role of the system 8 min

2.4 Validating that the rules work 7 min

After the lecture: LAB_03 starts — you harden your two machines, then write and test the firewall rules of each host.



How the 90 minutes are spent



Every lesson has the same shape

- Short, plain explanation of the terms
- A video under 15 minutes
- A NorthMaple example with a program you can run
- A diagram you can download
- Five flash cards and six questions

What you take away

- A hardening checklist filled with your own before/after evidence
- An inbound firewall rule table for every one of your hosts
- A test matrix that proves the rules work
- Chapter 3 of your Course Procedure Manual, written the same week



Where we stopped: LAB_02

Least privilege

Every account holds only the rights its role needs. Users are not local administrators.

Named administrator accounts

Administration uses personal accounts — the sudo group on Linux, the Administrators group on Windows. Never root, never the built-in Administrator.

The role table

Every host has a documented role and every account a documented job: file server, web server, accountant, technician, administrator.

?

Today's question follows from those three:

now that we know who may do what — what should each host run, and what should it accept from the network?



One rule before we start

You may

- Practice inside your own isolated laboratory (VirtualBox, or your own free-tier cloud account)
- Practice on another system only with written permission obtained before you start
- Use snapshots and isolated virtual networks so a mistake stays inside the laboratory

You must never

- Scan, probe or connect to any system that is not yours
- Run today's commands against the college, an employer, a business or a neighbour
- Use any tool of this course to break a law or a policy that applies to you

Unauthorized computer use is a criminal offence in Canada

Criminal Code sections 342.1 (unauthorized use of a computer), 342.2 (possession of a device to obtain unauthorized use) and 430(1.1) (mischief in relation to computer data). Penalties can include imprisonment. If an activity seems to touch a system you do not own — stop and ask.

Before the first change of LAB_03: sign the session acknowledgment, then take a snapshot of every virtual machine.



Part 1 — Hardening

Removing or disabling everything a system does not need.

- 1.1 What hardening means
- 1.2 Measures for Windows and Linux hosts
- 1.3 Monitoring and remediating vulnerabilities
- 1.4 Validation with free baseline checklists

Deliverable of Part 1

- The ten-item hardening checklist applied to your Windows machine and to your Linux machine
- A BEFORE and an AFTER state for every item



Hardening: changing the default state

The starting point

A newly installed system is configured for **compatibility**, not for security: services nobody uses are enabled, well-known accounts exist, settings are set so that every feature works on day one.

Hardening

Every component the host does not need for its **role** is removed, disabled or restricted — and everything that stays is set to its safest working value.

The four hardening actions

1

Remove

Uninstall software the role does not need
Purge the database engine left by the image

2

Disable

Stop a service and prevent it from starting again
Switch off printing on a server that prints nothing

3

Restrict

Keep the function, limit who may use it
Keep SSH, allow it only from the administrator

4

Update

Replace vulnerable versions with corrected ones
Install security updates every week



The attack surface: five things you can count

1

Listening services

Programs waiting for connections on a port (0–65535). Code anyone who reaches the port can run remotely.

2

Accounts

Every enabled account is a credential that can be guessed, stolen or reused.

3

Installed software

Every package carries its own defects. Software that is not installed cannot be exploited.

4

Features and protocols

Legacy versions and optional features add code paths that are less tested.

5

Configuration values

Password rules, timeouts, logging switches, permission defaults.

It is measurable

A host listening on eight ports has a larger attack surface than the same host listening on two. The count before and the count after are two numbers that belong in your manual.

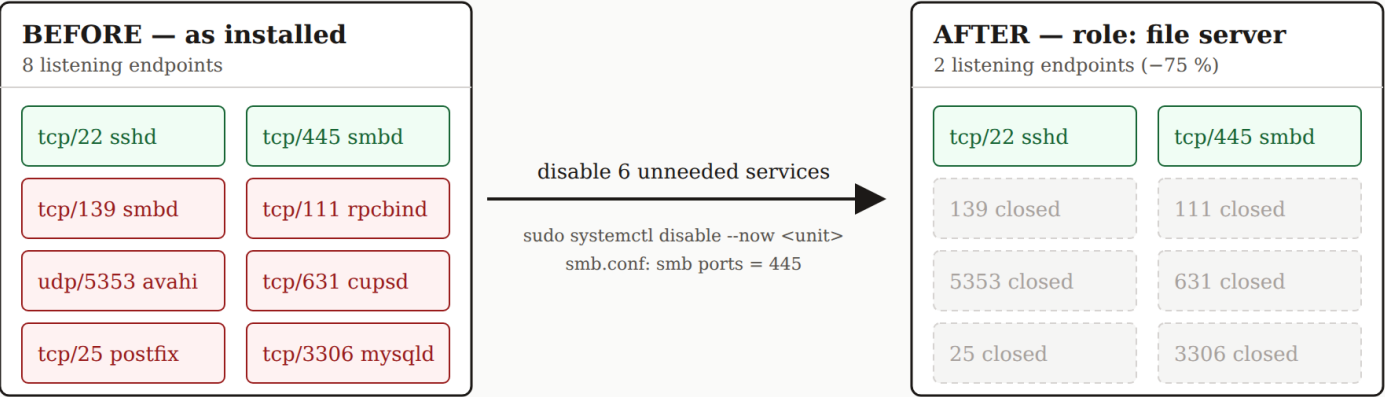
Two principles working together

- **Least privilege** — what an account may do (LAB_02)
- **Least functionality** — what a system runs (today). Named in the NIST catalogue of security controls as CM-7.
- An accountant who cannot install software, on a workstation that offers no service, is protected twice.



The file server with eight open doors

Attack surface of FS-01 (file server) — before and after hardening



■ required by the role (keep) ■ not required (disable) ■ closed after hardening

Measured with: `sudo ss -tulpn` (before) and again after the changes. Record both counts in the manual.

Cyber.SoHo — Cyber Defense (420-D03-AB) — Classes 5 & 6

The same host before and after: six unneeded services disabled, the two the role needs kept. Download this diagram from the lecture page.

What the technician did

- Listed the listening endpoints with `sudo ss -tulpn`
- Read the role: file server
- Kept 445 (file service) and 22 (administration)
- Disabled the six others

8 → 2
listening endpoints

75 %
smaller attack surface

Feeds: LAB_03 part 1 (service inventory and before/after record) · LAB_05 (the same inventory becomes the device registry)



Windows hardening (1/3) — accounts



Guest account

Disabled. A predictable name is the first thing an attacker tries.

```
Disable-LocalUser -Name Guest
```



Built-in Administrator

Disabled; you use the named administrator account created in LAB_02. Its SID always ends in -500, so it is predictable too.

```
Disable-LocalUser (SID ...-500)
```



Minimum password length

12 characters in this course (the CIS Benchmark for domain members recommends 14).

```
net accounts /minpwlen:12
```



Account lockout threshold

Five failed attempts, so password guessing stops after a few tries.

```
net accounts /lockoutthreshold:5
```

Where to look

`net accounts` shows the current policy.

`secpol.msc` opens the Local Security Policy console for the graphical path.

Why it matters

- Fewer accounts to guess
- Guessing stops after five tries
- Short passwords become impossible



Windows hardening (2/3) — services and policies

Services

Remote Registry

Disabled — it allows remote edits of the registry.

SMB version 1

Disabled — the obsolete file-sharing version that worms used to spread in 2017.

Print spooler

Disabled on a server that never prints.

Updates

Automatic installation

Windows Update installs Microsoft's monthly corrections.

Recent state

Get-HotFix lists what is installed; newer than 30 days is the target.

Security policies

User Account Control

Asks for consent before an administrative action (EnableLUA = 1).

Defender real-time protection

Scans files as they are opened.

Logon audit logging

Records who signed in and when — this feeds LAB_04.

Services console: services.msc • PowerShell: Get-Service, Set-Service, Get-SmbServerConfiguration, Get-MpComputerStatus, Get-HotFix



Linux hardening (3/3) — services, SSH, updates

Services (systemd)

- `systemctl list-units --type=service --state=running`
- `sudo ss -tulpn`
- `sudo systemctl disable --now <unit>`
- Usually disabled: avahi-daemon, cups, rpcbind

Accounts

- No account with an empty password
- Unused accounts locked with `passwd -l`
- Administration through the sudo group (LAB_02)

SSH — the administrative door

- `PermitRootLogin no`
- `PasswordAuthentication no`
- `MaxAuthTries 3`
- `X11Forwarding no`
- All four live in `/etc/ssh/sshd_config`
- `sudo sshd -t` validates the file before a restart
- `sudo sshd -T` prints the effective settings, including those not written in the file
- **Install your key first, and keep the current session open until a second session works.**

Updates

- `sudo apt update && sudo apt upgrade`
- unattended-upgrades installs security corrections every day
- Red Hat family: dnf-automatic

The classic accident

- Switching password login off before installing a key locks you out of your own server.
- Work from the VirtualBox console, not only over SSH.



The ten-item checklist you will apply

Hardening measures by area — the ten-item checklist of LAB_03

Windows host	Linux host
Accounts • Guest disabled • Built-in Administrator (SID -500) disabled • Minimum password length 12 • Lockout threshold 5 • No account without password	Services • avahi-daemon disabled • cups disabled • rpcbind disabled • listeners = role only (ss -tulpn)
Services • Remote Registry disabled • SMB version 1 disabled	SSH settings • PermitRootLogin no • PasswordAuthentication no (keys) • MaxAuthTries 3 • X11Forwarding no
Updates • Newest update under 30 days • Windows Update automatic	Updates • apt upgrade weekly • unattended-upgrades on
Security policies • UAC on (EnableLUA = 1) • Defender real-time on • Logon audit logging (Level 2)	Accounts • No empty password • Unused accounts locked (passwd -l)

Every item: BEFORE evidence → change → AFTER evidence. Snapshot first; one change at a time

Cyber.Sofia — Cyber Defense (420-D03-AB) — Classes 5 & 6

Two columns

- W01–W10 for Windows
- L01–L10 for Linux
- Same four areas each

A complete row

- The item
- BEFORE evidence
- The change applied
- AFTER evidence

The checklist is also a CSV table and a sheet of the reference workbook — the status and the score compute themselves.



Vulnerabilities: the words and the sources

Vulnerability

A weakness in software, configuration or procedure that an attacker can use against the confidentiality, the integrity or the availability of a system.

CVE identifier

One name for one publicly known vulnerability, for example CVE-2024-3094, published by the CVE Program. Every vendor refers to the same weakness.

CVSS score

A severity from 0.0 to 10.0 under the Common Vulnerability Scoring System, published by FIRST.

Security update (patch)

The corrected version of the software that removes the vulnerability.

Where they live

The NIST National Vulnerability Database stores the identifiers, the scores and the affected product versions.

What you check weekly

- Linux: apt list --upgradable
- Windows: Windows Update
- Optional second opinion: Lynis (laboratory only)



The weekly cycle that keeps a host hardened

1

Discover

Know what you have: hosts, software, versions. Your service inventory is the first line.

2

Assess

Find which known vulnerabilities apply to those versions.

3

Prioritize

Two questions: how severe (CVSS) and how exposed (Internet, user zone, administrator only).

4

Remediate

Patch, change the configuration, disable the component, or add a firewall rule while waiting.

5

Verify and document

Run the check again and record the result with its date. An unverified fix is an assumption.

Configuration management in three words

- **Baseline** — the written list of approved values (your checklist)
- **Drift** — any difference between the host today and its baseline
- **Correction** — put the value back and record it, or update the baseline with a justification

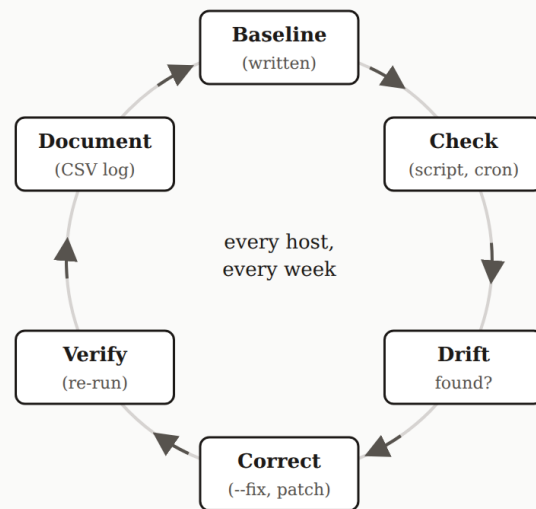
Two numbers per host

- Drifted items — target: zero
- Age of the oldest missing security update — target: under seven days



Monday morning drift on the file server

The weekly loop — baseline, check, drift, correction, verification, record



Vulnerability management (inside the loop)

- 1. Discover**
inventory of hosts, software, versions (ss -tulpn, device registry)
 - 2. Assess**
which vulnerabilities apply (apt list --upgradable, Windows Update, Lynis)
 - 3. Prioritize**
severity (CVSS, CISA KEV) × exposure (Internet / user zone / admin only)
 - 4. Remediate**
patch, configure, disable, or compensate (firewall rule)
 - 5. Verify & document**
re-run the check; date and evidence in the register
- Targets: 0 drifted items; oldest missing security update < 7 days.

Cyber.SoHo — Cyber Defense (420-D03-AB) — Classes 5 & 6

What happened

- An update reinstalled the printing service
- A technician re-enabled SSH password login to help a colleague — and forgot
- Nobody noticed until the weekly check ran at 07:00

Two DRIFT lines

- `sshd:passwordauthentication expected=no observed=yes`
- `service:cups expected=disabled observed=enabled`

The fix run

- Snapshot, then --fix: dated backup, sshd -t validates the file, the service restarts, cups is disabled — second run: zero drift.

The CSV log now holds the history: when the drift appeared and when it was corrected.



Free baseline checklists — who publishes them

Baseline

A published list of configuration settings with, for each one, the recommended value and the reason.

Benchmark

A baseline written so that it can be audited: every recommendation states how to check the current value and how to change it.

CIS Benchmarks

Consensus baselines for more than 100 technologies, including Windows 10 and 11, Windows Server, Ubuntu, Debian and Red Hat. Free PDF after registration.

Canadian Centre for Cyber Security

The Canadian baseline controls for small and medium organizations.

Microsoft Security Baselines

Microsoft's recommended settings for Windows and Edge, in the free Security Compliance Toolkit.

Lynis

A free, open-source Linux auditing tool that prints hardening suggestions with a score.

DISA STIGs

Public Security Technical Implementation Guides — stricter than CIS Level 1.



Levels, exceptions, and the score

Level 1 — essential

- Settings that apply to any system with little or no loss of functionality.
- The ten NorthMaple items are Level 1 in spirit.

Level 2 — stronger

- Settings for environments that need more protection and accept reduced functionality.
- Level 2 includes Level 1.

How you validate a host

- 1 Choose the benchmark and the profile (Level 1 for every NorthMaple host)
- 2 Audit each item and capture the observed value
- 3 Record PASS or FAIL with the evidence
- 4 Remediate the failures and audit again
- 5 Document every exception with a written justification
- 6 Compute the score: $\text{passed} \div \text{scored}$ (exceptions leave the denominator)

Validation vs verification

Validation compares values with the baseline. Verification tests that the control really works — for example a root login over SSH that must be refused (Lesson 2.4).

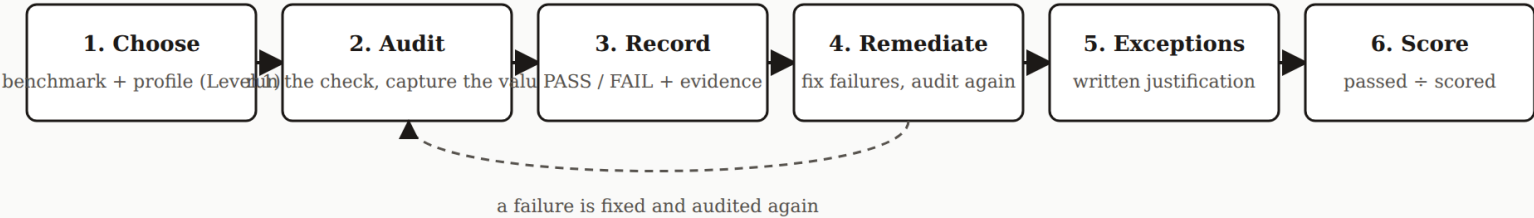
An exception is a decision, not a gap

Written justification, a compensating control where possible — and it never counts as a pass.



Scoring one workstation against ten items

Validation flow — from benchmark to documented score



100 %

Level 1 — 8 of 8 items

89 %

Level 2 — 8 of 9 scored

Example — WS-WIN-01, ten items

- B01-B08 (Level 1) 8 PASS
- B09 (Level 2) EXCEPTION — keys distributed at LAB_06; MaxAuthTries 3 limits exposure
- B10 (Level 2) FAIL — logon audit logging off → to-do list

Score: Level 1 = 8/8 (100 %) · Level 2 (cumulative) = 8/9 (89 %) · exceptions excluded from the denominator

Validation compares values with the baseline; verification (Lesson 2.4) tests that the control works. The manual needs both, Cyber.SoHo — Cyber Defense (420-D03-AB) — Classes 5 & 6

1 exception

- SSH password login stays on until the keys are distributed at LAB_06; MaxAuthTries 3 limits the exposure.

That sentence opens the validation section of your manual chapter.

1 item to fix

- Logon audit logging is off with no justification — it goes on the to-do list, and the audit is run again.



LAB_03 part 1 — what you do in the work time

Steps

- Snapshot both virtual machines
- Apply the ten Windows items and the ten Linux items
- Capture a BEFORE and an AFTER state for every item
- Write a justification for every exception
- Save the evidence files next to your workbook

Tools on the lecture page

- nm_attack_surface.py — service inventory and before/after counts
- nm_win_hardening_check.ps1 — ten Windows items, -Apply and -WhatIf
- nm_linux_drift_check.sh — baseline comparison, --fix
- nm_baseline_audit.py — Level 1 and Level 2 scores
- The reference workbook — sheets 01 to 04

What proves the work

A checklist row is complete when it holds the item, the BEFORE evidence, the change applied and the AFTER evidence. The status and the score in the workbook compute themselves — if a row still says "pending", the state is missing.



Part 2 — Host firewalls

What the machine accepts from the network.

- 2.1 Host firewalls versus network firewalls
- 2.2 Windows Defender Firewall, UFW, firewalld
- 2.3 Rules chosen by the role of the system
- 2.4 Validating that the rules work

Deliverable of Part 2

- An inbound rule table for every host, each rule scoped and justified
- A test matrix with the observed result of every rule



What a firewall reads in every packet

Source address

Where the packet comes from

Destination address

Where it is going

Protocol

TCP, UDP or ICMP

Destination port

Which service endpoint (0–65535)

A rule is a condition on those fields plus an action. Two more properties matter on a host:

Direction

Inbound traffic arrives at the host; outbound leaves it. Inbound rules protect the services of the host; outbound rules limit what the host may contact.

State

A stateful firewall remembers the connections it allowed, so the answers to a connection your host opened are accepted without any inbound rule.

The default policy of every host in this course

- **Default deny inbound, default allow outbound** — nothing reaches the host unless a rule allows it, while the host can still download updates, resolve names and open the shared folder.



Two firewalls, two different jobs

Network firewall — between the zones

- It is the pfSense or OPNsense appliance of LAB_05
- Every packet that crosses a zone boundary passes through it
- It enforces the zoning table of LAB_01
- One rule set protects many hosts, managed in one place
- It never depends on the configuration of the hosts behind it

Host firewall — inside every machine

- Windows Defender Firewall; on Linux the netfilter framework through UFW or firewalld
- It sees every packet addressed to the host, including packets from the same zone
- It is the only layer that stops lateral movement
- On Windows it can allow a port only for a named program
- It travels with the host — a laptop on public Wi-Fi keeps its rules

Its limit

- It sees only what crosses it. Two workstations in the same zone talk through the switch and never reach it.

Its limit

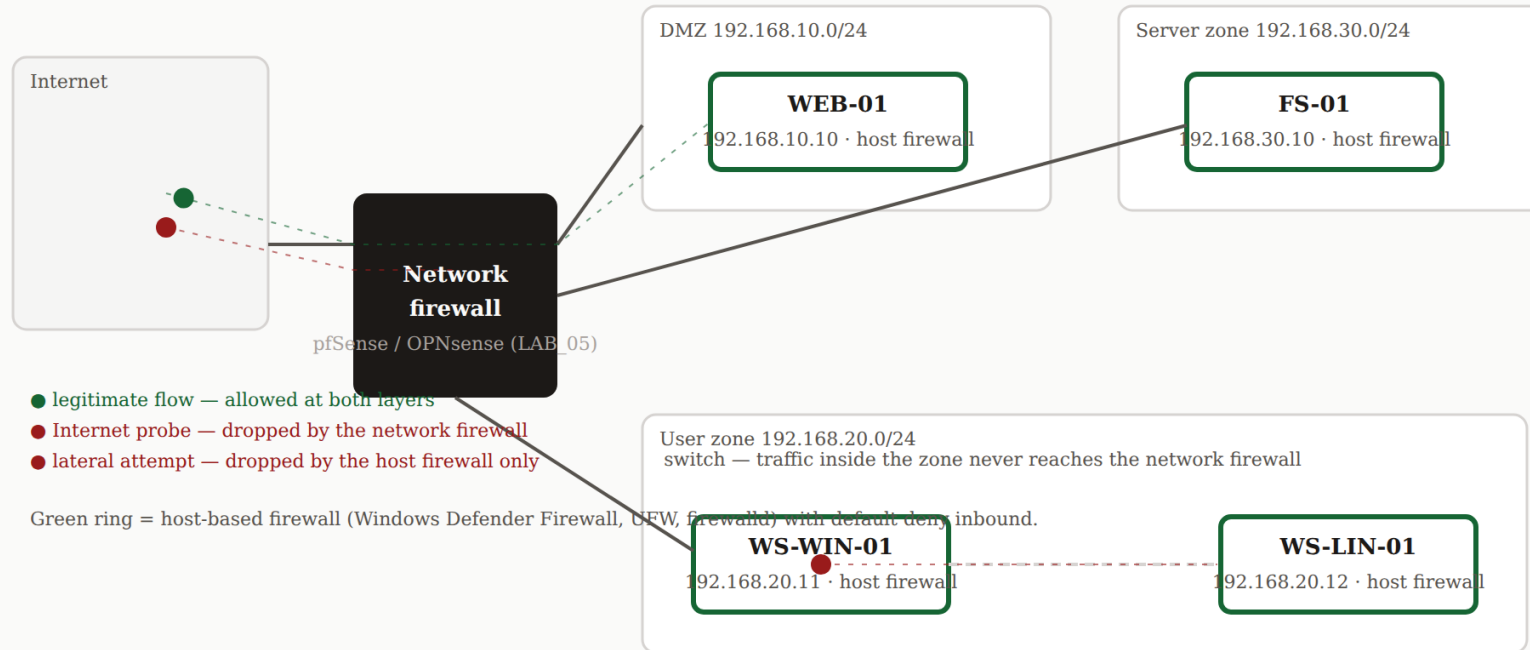
- It must be configured on every host, and anyone with administrative rights on that host can switch it off (hence least privilege).

They fail differently — that is the whole point of defense-in-depth: a wrong rule on the network firewall exposes a zone, a wrong rule on a host exposes one host.



Where each firewall sits

Where each firewall sits — network firewall between zones, host firewall inside every host



Cyber.SoHo — Cyber Defense (420-D03-AB) — Classes 5 & 6

Green ring = host firewall with default deny inbound. Download this diagram from the lecture page.

Allowed at both layers

- A customer reaching the public website on port 443

Stopped at the perimeter

- An Internet probe against the file server on port 445

Stopped by the host only

- Malware moving from one workstation to its neighbour — the network firewall never sees it



Six packets through the NorthMaple network

Packet	Flow	Network	Host	Verdict	Decided by
Accountant opens a shared folder	user → server, 445	allow	allow	ALLOWED	both layers
Administrator manages the file server	user → server, 22	allow	allow	ALLOWED	both layers
Customer visits the public website	Internet → DMZ, 443	allow	allow	ALLOWED	both layers
Internet attacker probes the file server	Internet → server, 445	deny	deny	BLOCKED	network firewall
Malware spreads to the next workstation	user → user, 445	not seen	deny	BLOCKED	host firewall
Malware tries SSH on the file server	user → server, 22	allow	deny	BLOCKED	host firewall

Two of the three hostile packets are stopped by the host firewall alone — the layer you build today.



The order that prevents a lock-out

The safe order of operations — the sequence that prevents a lock-out

- 1 **Console + snapshot**
work from the VM console, not only over SSH/RDP
- 2 **Write the rule table**
role → services → allowed sources (Lesson 2.3)
- 3 **Management rule first**
SSH / RDP from the administrator workstation only
- 4 **Default policies**
deny inbound · allow outbound
- 5 **Role rules, scoped**
one rule per service, smallest source
- 6 **Logging, then enable**
blocked packets logged before the first drop
- 7 **BEFORE / AFTER evidence**
status numbered saved twice

Same order, three tools

Windows Defender Firewall

```
New-NetFirewallRule -DisplayName 'NM-FS-01 ...' -LocalPort 22
-RemoteAddress 192.168.20.12 -Action Allow
Set-NetFirewallProfile -All -Enabled True
-DefaultInboundAction Block -LogBlocked True
```

UFW (Ubuntu / Debian)

```
ufw allow from 192.168.20.12 to any port 22 proto tcp
ufw default deny incoming · ufw logging on · ufw enable
```

firewalld (Red Hat family)

```
firewall-cmd --permanent --add-rich-rule=
'rule family=ipv4 source address=192.168.20.12 service name=ssh accept'
firewall-cmd --set-log-denied=all · firewall-cmd --reload
```

Rule names carry the NM- prefix;
every rule is scoped to a host or a zone.

Cyber.SoHo — Cyber Defense (420-D03-AB) — Classes 5 & 6

Why this order

- The management rule exists before the door closes
- Logging is on before the first packet is dropped
- The two status files are your BEFORE/AFTER evidence

Always

- Work from the VM console
- Take a snapshot first
- Write the rule table before typing

Same seven steps on Windows Defender Firewall, on UFW and on firewalld — only the commands change.



Windows Defender Firewall

Three profiles, all three on

- **Domain** — the host sees a domain controller
- **Private** — a network the user marked as trusted, such as the office
- **Public** — any other network, such as a café

Three habits that keep the rule set clean

Give every company rule the NM- prefix · scope every rule to an address or a zone · never disable the firewall to "test" — create a temporary scoped rule instead.

Show the state of the three profiles	Get-NetFirewallProfile Format-Table Name, Enabled, DefaultInboundAction
Enable all, block inbound, log blocked packets	Set-NetFirewallProfile -All -Enabled True -DefaultInboundAction Block -DefaultOutboundAction Allow -LogBlocked True
Allow Remote Desktop from the administrator only	New-NetFirewallRule -DisplayName "NM-WS-01 RDP from administrator" -Direction Inbound -Protocol TCP -LocalPort 3389 -RemoteAddress 192.168.20.12 -Action Allow
List the enabled inbound rules	Get-NetFirewallRule -Direction Inbound -Enabled True Format-Table DisplayName, Action, Profile

Graphical path: wf.msc (Windows Defender Firewall with Advanced Security) · Blocked packets: %SystemRoot%\System32\LogFiles\Firewall\pfirewall.log

UFW on Ubuntu and Debian

State and rules	<code>sudo ufw status verbose</code> · <code>sudo ufw status numbered</code>
Default policies	<code>sudo ufw default deny incoming</code> · <code>sudo ufw default allow outgoing</code>
Management rule, scoped	<code>sudo ufw allow from 192.168.20.12 to any port 22 proto tcp comment 'NM-FS-01 SSH from admin'</code>
Role rule, scoped to the zone	<code>sudo ufw allow from 192.168.20.0/24 to any port 445 proto tcp comment 'NM-FS-02 SMB from user zone'</code>
Slow down guessing	<code>sudo ufw limit 22/tcp</code>
Logging, enable, delete rule 3	<code>sudo ufw logging on</code> · <code>sudo ufw enable</code> · <code>sudo ufw delete 3</code>

deny or reject?

- deny drops the packet silently — the sender sees a timeout and learns nothing
- reject answers with an error immediately

What it really is

A front end for the netfilter framework of the Linux kernel.

Evidence

- Blocked packets appear in `/var/log/ufw.log` once logging is on



firewalld on the Red Hat family

Zones, not a flat list

firewalld organises rules in zones — sets of rules attached to an interface or to a source address range. The default zone public allows almost nothing inbound, which is the right starting point.

Two configurations

A rule written without --permanent is active now and disappears at the next restart of the service. Write it with --permanent, then apply it with --reload.

State and active zones

```
sudo firewall-cmd --state      ·      sudo firewall-cmd --get-active-zones
```

Allow a service or a port

```
sudo firewall-cmd --permanent --zone=public --add-service=ssh      ·      --add-port=445/tcp
```

Restrict a service to one source (rich rule)

```
sudo firewall-cmd --permanent --zone=public --add-rich-rule='rule family=ipv4 source address=192.168.20.12 service name=ssh accept'
```

Log denied packets, apply, list

```
sudo firewall-cmd --set-log-denied=all      ·      --reload      ·      --list-all
```

Denied packets appear in journalctl -k once --set-log-denied=all is set.



Secure or insecure? Read the source

Insecure

```
sudo ufw allow 22/tcp
```

"Allow SSH" opens the door to the whole network — including a workstation that has just been compromised by a phishing attachment.

Secure

```
sudo ufw allow from 192.168.20.12 to any port 22  
proto tcp
```

The same service, reachable from one machine only: the administrator workstation.

It is rarely the list of ports that makes a rule set weak — it is the source address of each rule.

Scope

- The smallest set of sources that needs the service

Name

- The NM- prefix, so the rule can be found, exported and cited in the manual

Justify

- One plain sentence per rule — the grading checklist gives half a point for it



The role decides what the host accepts

A workstation is a client

- It opens connections to servers and receives the answers through the stateful mechanism
- It offers no service, so its inbound table is nearly empty
- One optional rule: remote help from the administrator (RDP 3389 on Windows, SSH 22 on Linux)

A server offers services

- One row per service the role really offers
- Each row names the source that may use it
- Management (SSH or RDP) is always scoped to the administrator workstation

Closed between workstations — on purpose

- TCP 445 (file sharing) and the NetBIOS ports 137–139 are the ports worms and ransomware use to move from one workstation to the next.
- The default deny inbound policy closes them without any rule.

Where the rule comes from

- The zoning table of LAB_01 says where the host sits and which traffic may reach its zone
- The role table of LAB_02 says who uses it
- The host rule narrows that to the smallest source — it refines the zoning table, never contradicts it



The NorthMaple inbound rule matrix

Inbound rule matrix — who may reach which port (the role decides)

Host (role, zone)	TCP 22 SSH	TCP 80 HTTP	TCP 443 HTTPS	TCP 445 SMB	TCP 3389 RDP
WEB-01 · web server · DMZ	admin	Any	Any	default deny	default deny
FS-01 · file server · server zone	admin	default deny	default deny	user zone	default deny
IDS-01 · sensor · server zone	admin	default deny	default deny	default deny	default deny
WS-WIN-01 · accountant · user zone	default deny	default deny	default deny	default deny	admin
WS-LIN-01 · administrator · user zone	default deny	default deny	default deny	default deny	default deny

admin = the administrator workstation 192.168.20.12 only · user zone = 192.168.20.0/24 (+ VPN network after LAB_06)
"Any" appears only for the public website · every other cell: default deny inbound. Cyber.SoHo — Cyber Defense (420-D03-AB) — Classes 5 & 6

Read a column

- Who may reach that port on each host

Read a row

- Everything one host accepts — the rest is default deny

"Any" appears once, for the public website. The administrator workstation appears in almost every row — and accepts nothing itself.

Four patterns in every good rule

1

Minimal

One row per service the role really offers. The web server has no file-sharing rule; the file server has no web rule.

2

Scoped

The source is the smallest set that needs the service. "Any" appears only for a genuinely public service.

3

Named and justified

A rule name with the company prefix, and one plain sentence saying why the rule exists.

4

Consistent with the zoning table

Every allowed source is a zone or a host that LAB_01 already allows to reach that zone.

Last check of the lab: a disabled service needs no rule, and a rule for a service that does not exist means your two lists are out of date.



A rule that exists is not a rule that works

The test matrix

One row per test: the source (a machine of your laboratory), the destination and port, the expected result (ALLOW or BLOCK), the observed outcome, the verdict and the evidence.

Positive test

- From an allowed source — expected ALLOW
- Proves the service is reachable by the people who need it

Negative test

- From a denied source — expected BLOCK
- This is the one that catches mistakes: a rule scoped too widely passes every positive test

Every rule produces at least two rows.

Legal reminder — Legal Notice, section 3

Each test is one connection attempt to one port of one of your own virtual machines, inside your isolated laboratory. Nowhere else.



Three outcomes, three meanings

open — A service answered.

Expected ALLOW → PASS. Expected BLOCK → FAIL: the rule does not do what you think.

refused — The host answered immediately that nothing listens on that port.

The packet reached the host — the firewall did not drop it. For an ALLOW test it usually means the service is not started: check with `ss -tulpn`.

timeout — No answer at all.

The packet was dropped by a firewall, or the host is down. For a BLOCK test with a deny rule, this is the correct result.

One connection attempt

- `Test-NetConnection -ComputerName 192.168.30.10 -Port 445`
- `nc -zv 192.168.30.10 445`
- `curl -I https://192.168.10.10 -k`
- `sudo ss -tulpn` (on the target, before blaming the firewall)
- `nmap -p 22,445,3389 192.168.30.10` (your own machines only)

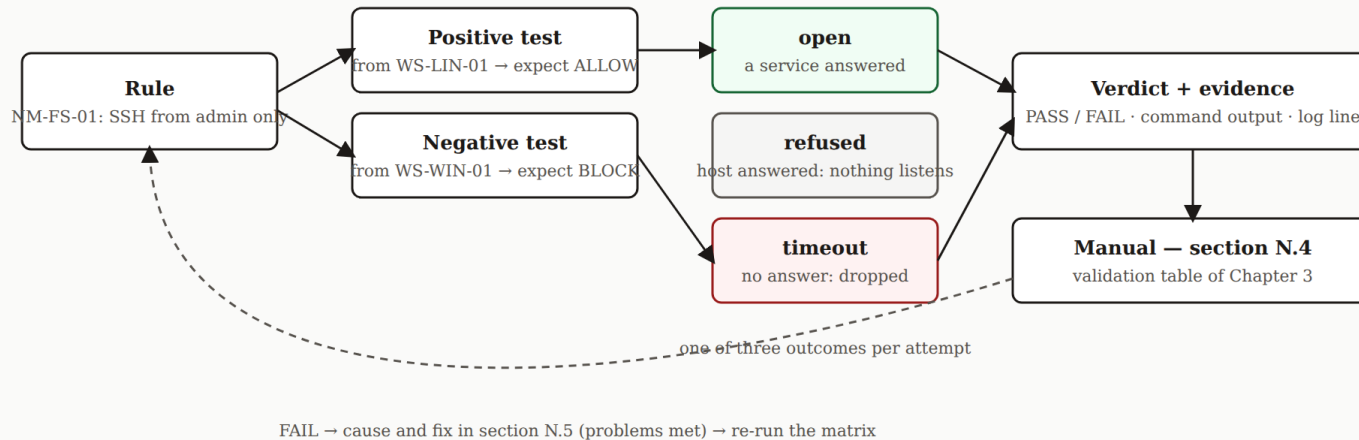
Strongest evidence of a BLOCK

The log line on the target: [UFW BLOCK] or a DROP line in `pfirewall.log`.



Six tests from three chairs

From rule to evidence — every rule gets a positive and a negative test



Tools: Test-NetConnection -Port (Windows) · nc -zv (Linux) · curl -I · ss -tulpn on the target · nmap only inside your own laboratory.

Evidence of a BLOCK: pfirewall.log DROP line · /var/log/ufw.log [UFW BLOCK] · journalctl -k (firewalld, --set-log-denied=all).

Cyber.SoHo — Cyber Defense (420-D03-AB) — Classes 5 & 6

The sixth test: the rule was right, the service was not running

- "refused" proves the packet reached the host. The cause and the fix go into the "problems met" section, and the matrix is run again.

The six rows

From the accountant workstation

- shared folder opens (ALLOW)
- SSH to the file server times out (BLOCK)
- file sharing to the next workstation times out (BLOCK)

From the DMZ web server

- the file server is unreachable (BLOCK)

From the administrator workstation

- SSH to the file server opens (ALLOW)
- Remote Desktop answers "refused" — FAIL



LAB_03 part 2 — what you do in the work time

Steps

- Write the inbound rule table of each host from its role
- Apply the rules in the safe order — management rule first
- Switch logging on, then enable the firewall
- Run the test matrix from three vantage points
- Record the observed outcome and the evidence of every row

Tools on the lecture page

- nm_two_layer_filter.py — see which layer decides a packet
- nm_ufw_filesaver.sh — the UFW sequence, dry run by default
- nm_role_firewall_rules.ps1 — the Windows rule set of a role
- nm_rule_validation.py — runs the matrix and writes the evidence
- The reference workbook — sheets 05 to 07

Deliverable of LAB_03 — the host-security chapter

Hardening checklist results with before/after evidence, the firewall rule tables, and the test evidence. That is Chapter 3 of your Final Project and of your Course Procedure Manual — written this week, not in October.



Where today's work comes back

LAB_04

Classes 7–8

Your logon audit events and firewall logs feed the detection sensor.

LAB_05

Classes 11–12

The service inventory becomes the device registry; the same sources become the network firewall rules.

LAB_06

Classes 16–17

The VPN network is added as an allowed source on the file server, and the matrix is run again.

Final Project

Chapter 7

Scenarios 1, 3 and 4 of the resilience assessment are answered with today's host firewall results.

Nothing you do today is thrown away: every table and every screenshot is a chapter of the Final Project.



Evaluation — what comes next

No quiz in this session

- The session plan reads "No quiz this session" for Classes 5 and 6.

Q_02 — Class 9, Saturday September 19 (2.5 %)

- Covers Classes 3 to 8, including hardening principles and the purpose and basic rules of host firewalls.

Mid-Term Exam — Class 10 (10 %)

- Closed book, Classes 1 to 9 — today's material is part of it.

How to prepare

- The flash cards and the six questions of every lesson on the lecture page
- Your own before/after evidence — the best revision material you will have



Videos for this session

1.1

Hardening Techniques — CompTIA Security+ 2.5 (12:11)

https://www.youtube.com/watch?v=wXoC46Qr_9Q

1.2

5 Steps to Secure Linux — SSH, keys and updates

<https://www.youtube.com/watch?v=ZhMw53Ud2tY>

1.4

Secure Baselines — CompTIA Security+ 4.1 (4:11)

<https://www.youtube.com/watch?v=BWPJD9Eb9iE>

2.1

Firewall Types — CompTIA Security+ 3.2 (8:00)

<https://www.youtube.com/watch?v=mq1HRM-zGtQ>

2.2

Configure Windows Firewall rules — Microsoft Learn

<https://learn.microsoft.com/en-us/windows/security/operatin...>

1.2

Hardening Targets — CompTIA Security+ 4.1 (10:11)

<https://www.youtube.com/watch?v=YQKbsougoXQ>

1.3

Vulnerability Remediation — CompTIA Security+ 4.3 (8:45)

<https://www.youtube.com/watch?v=P9xakfmX7oc>

1.4

CIS Benchmarks — the official overview page and video

<https://www.cisecurity.org/cis-benchmarks-overview>

2.2

UFW Made Easy — complete getting started guide

<https://www.youtube.com/watch?v=F-ubkT1WNfk>

2.3

Firewalls — CompTIA Security+ 4.5 (11:31)

<https://www.youtube.com/watch?v=VgNyh4HEqSU>

Before opening any external link on a laboratory machine, check it with the VirusTotal URL scanner (Legal Notice, section 10).



Official sources (1/2)

[Center for Internet Security](#)

The Benchmarks and the Critical Security Controls.

[NIST](#)

Publishes the Special Publication 800 series used today.

[National Vulnerability Database](#)

Published vulnerabilities with their severity scores.

[Canadian Centre for Cyber Security](#)

Baseline controls for small and medium organizations in Canada.

[MITRE ATT&CK](#)

Attacker techniques — the Lateral Movement tactic explains host firewalls.

[CIS Benchmarks catalogue](#)

Free configuration baselines per operating system.

[NIST Computer Security Resource Center](#)

Entry point for the publications and the National Checklist Program.

[CVE Program](#)

The authoritative list of CVE identifiers.

[Criminal Code of Canada](#)

Sections 342.1, 342.2 and 430(1.1) cited in the Legal Notice.

[VirusTotal URL scanner](#)

Check any link before you open it.



Official sources (2/2)

[Microsoft Learn](#)

Windows security settings, Defender Firewall, NetSecurity cmdlets.

[Ubuntu community — UFW](#)

Practical reference for the commands of Lesson 2.2.

[OpenSSH project](#)

The SSH server used on every Linux host of the laboratory.

[DISA STIGs](#)

Free hardening guides, stricter than CIS Level 1.

[OpenSCAP](#)

Free tools that evaluate a Linux system against SCAP content.

[Ubuntu \(Canonical\)](#)

Updates, unattended-upgrades and UFW documentation.

[firewalld project](#)

Zones, rich rules and the permanent configuration.

[sshd_config manual page](#)

Every setting audited in Lesson 1.2.

[Lynis](#)

Free Linux auditing tool — laboratory use only.

[Nmap project](#)

Port scanner — your own virtual machines only.



What to remember

1

Hardening is measurable

Count the listening endpoints before and after. Eight to two is a 75 % smaller attack surface.

2

The role decides everything

What the host runs (Part 1) and what it accepts (Part 2) both come from the zoning table and the role table.

3

Two layers, two jobs

The network firewall protects the zones; the host firewall is the only one that stops movement inside a zone.

4

Scope every rule

It is the source address, not the port list, that makes a rule set secure.

5

A rule is not validated until it is tested

One positive test and one negative test per rule, with the evidence recorded.



Now: supervised work time

On your screen

- The lecture page (all scripts and diagrams are downloadable from it)
- The reference workbook
- Your Chapter 3 document
- The LAB_o1 zoning table and the LAB_o2 role table

First three moves

- Snapshot both virtual machines
- Run the audit scripts in check mode (no change)
- Write your rule table on paper before typing a single command

Ask for help when

- A machine stops answering after a change — revert to the snapshot and call me
- A test gives "refused" where you expected "open"
- You are not sure whether a service is needed by the role

Everything happens inside your own isolated laboratory. Break at 10:30.

